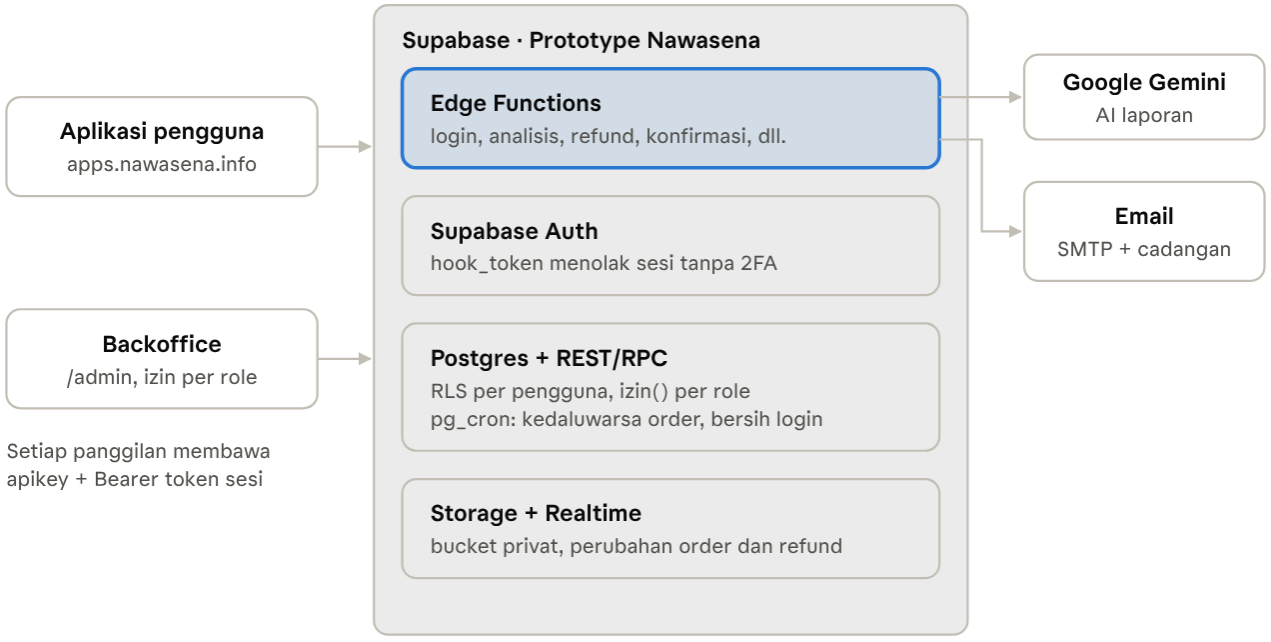
API List Nawasena

Nov 14, 2026 · @Alif Rodiansyah

Ringkasan

Semua API Nawasena berjalan di satu proyek Supabase (Prototype Nawasena). Aplikasi pengguna dan backoffice memanggil tiga jenis endpoint: Edge Functions untuk logika yang butuh kunci rahasia (AI, email, login, upload), RPC database untuk aturan bisnis, dan REST tabel yang dijaga Row Level Security.

Semua API lewat satu proyek Supabase; kunci rahasia hanya di Edge Functions



arsitektur API · 2 klien, 4 layanan Supabase, 2 layanan luar

Browser tidak pernah memegang kunci rahasia: AI dan email hanya dipanggil dari Edge Functions, sementara REST/RPC dan Storage dijaga RLS.

Jenis	Base URL	Dipakai untuk
Edge Function	`https://qgauvnqescvpyyyhpzws.supabase.co/functions/v1/<nama>`	Login & 2FA, analisis AI, konfirmasi bayar, refund, kelola akun admin
RPC database	`https://qgauvnqescvpyyyhpzws.supabase.co/rest/v1/rpc/<nama>`	Order, kode referral/voucher, status refund, profil admin

Jenis	Base URL	Dipakai untuk
REST tabel	`https://qgauvnqescvpyyyhpzws.supabase.co/rest/v1/<tabel>`	Baca/tulis data milik sendiri (CV, jawaban, laporan) dan data backoffice
Storage	`https://qgauvnqescvpyyyhpzws.supabase.co/storage/v1/object/<bucket>/<path>`	Bukti bayar, receipt, CV, bukti transfer refund
Realtime	WebSocket Supabase	Perubahan order, laporan, refund, transfer salah

Header wajib. Semua panggilan membawa `apikey: <anon key>`. Panggilan atas nama pengguna atau admin membawa `Authorization: Bearer <access token>`; panggilan sebelum login (login, daftar, lupa sandi) memakai anon key di kedua header.

Autentikasi. Sesi hanya diterbitkan oleh Edge Function `login` setelah kata sandi dan kode kedua (email atau Authenticator) lolos. Setelah hook `hook_token` dipasang di Supabase, token yang tidak lewat jalur itu ditolak.

Format galat. Edge Function membalas JSON `{ "galat": "pesan untuk pengguna", "kode"?: "ULANG" | "BELUM_ADA_SANDI" }` dengan status 4xx/5xx; teks `galat` aman ditampilkan apa adanya. RPC dan REST memakai format galat bawaan PostgREST (`message`, `code`).

Edge Functions

Ada 10 function, semuanya `POST` dengan body JSON. Function memeriksa sesi sendiri (verifikasi JWT bawaan Supabase dimatikan), dan function backoffice memeriksa izin role lewat RPC `izin(menu, aksi)`.

Function	Pemanggil	Akses	Fungsi
`login`	Aplikasi + backoffice	Publik (sebelum login) dan sesi	Login kata sandi + 2FA, daftar, lupa sandi, atur Authenticator, ganti sandi
`analisis`	Aplikasi	Sesi pengguna	Menyusun Bagian 1 (gratis) dari CV + kuis di latar belakang
`saran-target`	Aplikasi	Sesi pengguna	10 rekomendasi role sesudah kuis

Function	Pemanggil	Akses	Fungsi
`profil-cv`	Aplikasi	Sesi pengguna	Merapikan CV yang disusun di aplikasi menjadi profil
`laporan-lengkap`	Aplikasi, `konfirmasi`	Sesi pengguna lunas atau kunci internal	Menyusun Bagian 2–6 dalam tiga potongan (rencana, arahA, arahB)
`refund`	Aplikasi + backoffice	Sesi pengguna (ajukan), izin `refund:u` (lainnya)	Ajukan, proses, selesaikan (bukti transfer), tolak refund + email
`konfirmasi`	Backoffice	Izin `order:u`	Konfirmasi/tolak pembayaran, receipt, batalkan keputusan
`akun-admin`	Backoffice	Izin `akun:c/u/d`	Buat, ubah, reset sandi, reset 2FA, hapus akun backoffice; masa berlaku
`kirim-email-auth`	Supabase Auth	Signature hook	Send Email Hook pengganti SMTP bawaan
`masuk`	Aplikasi versi lama	Publik	Login OTP lama; tidak dipakai lagi setelah build keamanan diunggah

login

Aksi	Body	Balasan
`sandi`	`peran` (`pengguna` / `admin`), `akun` (email atau HP), `sandi`	`{ tantangan, tahap: email|totp|pilih, tujuan }`
`pilih`	`tantangan` , `metode` (`email` / `totp`)	Admin pertama kali: kode dikirim, atau `{ qr (svg), rahasia }`
`kirim_ulang`	`tantangan`	Kode baru ke email (jeda 60 detik)
`verifikasi`	`tantangan` , `kode` (6 angka)	`{ access_token, refresh_token }`
`daftar_kirim`	`email`	`{ tantangan, tujuan }`
`daftar_cek`	`tantangan` , `kode` , `sandi`	Akun dibuat + token sesi
`reset_kirim`	`akun`	`{ tantangan, tujuan }`

Aksi	Body	Balasan
`reset_cek`	`tantangan`, `kode`, `sandi`	Token sesi, atau `{ tantangan, tahap: totp }` kalau pakai Authenticator
`totp_mulai` *	–	`{ tantangan, qr, rahasia }`
`totp_aktifkan` *	`tantangan`, `kode`	`{ ok, metode: totp }`
`totp_matikan` *	`kode` (kode Authenticator saat ini)	`{ ok, metode: email }`
`ganti_sandi` *	`sandi_lama`, `sandi_baru`	`{ ok }`, perangkat lain keluar

* butuh sesi yang lolos dua langkah. Aturan: sandi minimal 8 karakter dengan huruf dan angka; 5 kata sandi salah per akun dalam 15 menit = dikunci sementara; 5 kode salah = tantangan hangus (`kode: ULANG`); kode email berlaku 10 menit.

refund

Aksi	Body	Akses
`ajukan`	`jenis` (`bank` / `ewallet`), `nama`, `nomor`, `pemilik`, `milik_lain`	Sesi pengguna yang memenuhi `syarat_refund`
`proses`	`id`	Izin `refund:u`
`selesaikan`	`id`, `bukti {nama, tipe, data base64}`, `tanggal`, `nominal` (harus penuh), `biaya`	Izin `refund:u`
`tolak`	`id`, `alasan`	Izin `refund:u`

konfirmasi

Aksi	Body	Hasil
`ok`	`pesanan_id`, `kwitansi {nama, tipe, data}` (wajib), `nominal_bukti`?	Lunas, receipt diemail, Bagian 2–6 mulai disusun
`tolak`	`pesanan_id`, `alasan`, `nominal_bukti` (wajib untuk "Nominal tidak sesuai tagihan")	Ditolak + dicatat sebagai transfer salah bila nominal

Aksi	Body	Hasil
`kwitansi`	`pesanan_id`, `kwitansi`	Ganti/kirim ulang receipt order lunas
`batal`	`pesanan_id`	Kembali ke Menunggu (keputusan sendiri, maks. 15 menit)

akun-admin

Aksi	Body	Izin
`buat`	`nama`, `email`, `hp`, `sandi`, `peran_id`, `berlaku_hari`?	`akun:c`
`ubah`	`user_id` + `nama` / `hp` / `peran_id` / `aktif` / `berlaku_hari`	`akun:u`
`sandi`	`user_id`, `sandi`	`akun:u`
`reset_2fa`	`user_id`	`akun:u`
`hapus`	`user_id`	`akun:d`

`berlaku_hari` = angka hari mulai hari ini (1–3650); kosong atau `null` = tanpa batas.

RPC aplikasi pengguna

Dipanggil dengan `POST /rest/v1/rpc/<nama>` dan body JSON berisi parameter. Semua fungsi `security definer` yang membaca pengguna dari token (`auth.uid()`), jadi pengguna hanya bisa menyentuh datanya sendiri.

RPC	Parameter	Akses	Hasil
`cek_kontak`	`p_email`, `p_hp`	Publik	Apakah email/HP sudah dipakai (saat daftar)
`cek_kode_referral`	`p_kode`	Publik	Kode referral/voucher valid + besar potongan
`simpan_profil`	`p_nama`, `p_tgl_lahir`, `p_hp`, `p_setuju`	Pengguna	Simpan profil + persetujuan UU PDP
`pakai_kode`	`p_kode`	Pengguna	Pasang/hapus kode referral atau voucher di akun

RPC	Parameter	Akses	Hasil
`info_referral`	–	Pengguna	Kode yang sedang terpasang + potongannya
`buat_pesanan`	`p_metode` (`qris` / `transfer`)	Pengguna	Order baru dengan kode unik, batas bayar 1 jam (atau order aktif yang ada)
`kirim_bukti`	`p_metode`, `p_bukti_path`, `p_bukti_nama`	Pengguna	Order jadi Menunggu dicek; dipakai juga untuk bayar ulang
`info_refund`	–	Pengguna	`{ syarat, refund }`: boleh ajukan atau tidak + refund terakhir
`coba_lagi_analisis`	–	Pengguna	Ulangi analisis Tertunda tanpa bayar ulang
`status_keamanan`	–	Pengguna	Metode 2FA (`email` / `totp`) + sudah punya kata sandi
`sudah_lunas`	`p_user`	Pengguna	Dipakai RLS untuk membuka laporan lengkap

Fungsi bantu yang terbuka untuk publik tapi tidak membuka data: `harga_paket`, `normal_hp`, `is_admin`, `adalah_admin`, `izin`, `profil_admin` (keduanya mengembalikan kosong/false tanpa sesi admin).

RPC backoffice dan internal

RPC backoffice dipanggil dengan token admin; setiap fungsi mengecek role, sesi 24 jam, dan masa berlaku akun lewat `izin()`. Fungsi internal hanya bisa dipanggil Edge Function (service role) atau Supabase Auth, tidak dari browser.

Backoffice (sesi admin)

RPC	Parameter	Hasil
`profil_admin`	–	Nama, role, izin per menu, mulai sesi, `sesi_ok`, `berlaku_sampai`, `kedaluwarsa`, `metode_2fa`
`izin`	`p_menu`, `p_aksi` (`r` / `c` / `u` / `d`)	`true` kalau role boleh; dipakai RLS dan Edge Function
`kedaluwarsakan_pesanan`	`p_user`?	Tandai order belum bayar yang lewat 1 jam
`rekap_voucher`	–	Terpakai, berjalan, total potongan per voucher
`rekap_ambassador`	–	Pendaftar, pembeli, komisi per ambassador
`hapus_ambassador`	`p_id`	Hapus ambassador + tautannya
`buat_tautan`	–	Kode tautan acak 6 karakter untuk ambassador
`catat_aktivitas`	`p_menu`, `p_aksi`, `p_ringkas`, `p_detail`	Tulis audit trail (login, logout, ekspor)
`status_2fa_admin`	–	Metode 2FA tiap akun backoffice (izin `akun:r`)

Internal (service role / Supabase Auth)

Fungsi	Dipanggil oleh	Kegunaan
`cek_sandi`, `punya_sandi`, `cari_user_email`	`login`	Cek kata sandi bcrypt, cari akun
`hook_token`	Supabase Auth (Custom Access Token Hook)	Tolak token yang tidak lewat dua langkah
`bersihkan_login`	pg_cron harian	Hapus tantangan, izin dan catatan login lama
`putuskan_pesanan`	`konfirmasi`	Konfirmasi/tolak/batal order + catat transfer salah + audit

Fungsi	Dipanggil oleh	Kegunaan
`syarat_refund`, `ajukan_refund`, `proses_refund`, `selesaikan_refund`, `tolak_refund`	`refund`	Aturan refund
`putus_sesi`	`akun-admin`, `login`	Keluarkan akun dari semua perangkat
`tulis_audit`	Semua fungsi admin	Audit trail append-only
`admin_berlaku`	`is_admin`	Cek akun aktif dan belum kedaluwarsa
`hitung_potongan`, `alasan_voucher`, `voucher_terpakai`, `potongan_voucher`	`buat_pesanan`	Hitung potongan voucher/referral
`simpan_potongan`, `tandai_potongan`	`analisis`, `laporan-lengkap`	Simpan potongan laporan AI
`segarkan_pesanan_aktif`, `analisis_tertunda`	Fungsi order dan refund	Bantu status order dan analisis

Tabel REST, realtime, dan storage

Semua tabel memakai Row Level Security. Pengguna hanya melihat barisnya sendiri; backoffice melihat data sesuai izin menu di role-nya. Tabel tanpa kebijakan untuk pengguna hanya bisa diakses Edge Function.

Tabel	Pengguna	Backoffice	Realtime
`profil`	Baca + ubah milik sendiri	Baca (admin)	–
`cv`, `jawaban`, `lampiran`	Baca/tulis milik sendiri	–	–
`laporan`	Baca milik sendiri (Bagian 1)	–	Ya

Tabel	Pengguna	Backoffice	Realtime
`laporan_lengkap`	Baca milik sendiri, hanya kalau lunas	–	Ya
`pesanan`	Baca milik sendiri (ubah lewat RPC)	Izin `order` / `keuangan` / `refund` baca	Ya
`refund`	Baca milik sendiri	Izin `refund` / `keuangan` baca	Ya
`transfer_salah`	Baca milik sendiri	Izin `order` / `refund` / `keuangan` baca	Ya
`masukan`	Kirim + baca milik sendiri	Baca (admin)	–
`voucher`	–	Izin `voucher` c/r/u/d, `keuangan` baca	–
`ambassador`, `target_ambassador`, `pembayaran_komisi`	–	Izin `ambassador` (+ `keuangan` baca komisi)	–
`rekonsiliasi`	–	Izin `keuangan` c/r/d	–
`riwayat_pesanan`	–	Izin `order` / `audit` baca	–
`audit_log`, `audit_admin`	–	Izin `audit` baca (append-only)	–
`admin`, `peran`	–	Baca (admin); ubah role lewat izin `akun`	–
`metode_2fa`, `tantangan_login`, `percobaan_login`	–	– (hanya function `login`)	–
`sesi_2fa`, `izin_login`	–	– (function `login` + hook Auth)	–
`urutan_pesanan`, `bukti_bayar`, `tokoh`, `peran_referensi`	–	– / baca admin	–

Storage (semua bucket privat, dibuka lewat signed URL 10–15 menit):

Bucket	Isi	Path	Siapa yang membaca
`cv`	CV unggahan	`<user_id>/…`	Pemilik
`lampiran`	Sertifikat, portofolio	`<user_id>/…`	Pemilik
`bukti`	Bukti bayar	`<user_id>/…`	Pemilik, admin izin `order`
`kwitansi`	Receipt pembayaran	`<user_id>/<pesanan>-<waktu>`	Pemilik, admin
`refund`	Bukti transfer refund	`<user_id>/<refund>-<waktu>`	Pemilik, izin `refund` / `keuangan`

Hook, cron, dan secret

Jenis	Nama	Jadwal / pemicu	Fungsi
Auth hook	Custom Access Token → `public.hook_token`	Setiap token diterbitkan/diperpanjang	Tolak sesi yang tidak lewat dua langkah (aktif setelah dipasang di Dashboard)
Auth hook	Send Email → `kirim-email-auth`	Email bawaan Supabase Auth	Kirim email lewat Resend/Brevo/SMTP2GO
Cron	`nawasena-kedaluwarsa`	Tiap 5 menit	`kedaluwarsakan_pesanan()` : order belum bayar > 1 jam jadi Kedaluwarsa
Cron	`bersihkan-login`	Setiap hari 03.17 UTC	`bersihkan_login()` : hapus data login yang sudah lama

Secret Edge Functions (Supabase → Edge Functions → Secrets; nilainya tidak pernah ditulis di dokumen atau repo):

Secret	Dipakai	Keterangan
`SMTP_HOST` , `SMTP_PORT` , `SMTP_USER` , `SMTP_PASS`	`login` , `konfirmasi` , `refund`	Email transaksi utama (port 465)
`EMAIL_PENGIRIM`	Semua function email	mis. `Nawasena <support@nawasena.info>`

Secret	Dipakai	Keterangan
`RESEND_API_KEY`, `BREVO_API_KEY`, `SMTP2GO_API_KEY`	Email cadangan + `kirim-email-auth`	Opsional, penyedia kosong dilewati
`SEND_EMAIL_HOOK_SECRET`	`kirim-email-auth`	Dari Authentication → Hooks → Send Email
`GEMINI_API_KEY` (+ `GEMINI_MODEL`, `GEMINI_MODEL_CEPAT`, `GEMINI_MODEL_CADANGAN`, `GEMINI_BATAS_MS`); cadangan `ANTHROPIC_API_KEY`, `CLAUDE_MODEL`, pemilih `AI_PROVIDER` / `MODE_AI`	`analisis`, `saran-target`, `profil-cv`, `laporan-lengkap`	Penyusun laporan dan rekomendasi
`APP_URL`	Email	Tautan "Buka Nawasena"
`NAWASENA_INTERNAL_KEY`	Panggilan antar-function	Opsional; tanpa ini diturunkan dari kunci service role

Kunci `SUPABASE_URL`, service role, dan anon key disediakan otomatis oleh Supabase untuk semua function.